

Mandatsnotiz

Lahnwerke Maschinenbau AG rollt Slack aus, verfolgt LKW-Werkzeugcontainer mit AirTags, betreibt MDM auf Firmenhandys und hat nach einem Lieferanten-VPN-Vorfall Zweifel an NIS-2-/BSI-Reife.

Beteiligte: Geschäftsleitung, Rechtsabteilung, operative Fachabteilungen, externe IT/Compliance-Berater und mehrere Personen mit eigenen Interessen. Die Akte ist bewusst unaufgeräumt: manche Unterlagen widersprechen sich, Zahlenstände weichen ab und einzelne Dokumente wirken bereits überholt.

Arbeitsziel heute: zuerst sortieren, dann keine vorschnelle Rechtsmeinung ausgeben. Jede harte Aussage soll auf ein konkretes Aktenstück oder eine frei prüfbare Quelle zurückgeführt werden.

Zeitstrahl

- 04.02.2026: erster interner Hinweis auf Lücken und unklare Verantwortlichkeiten.
- 18.03.2026: Fachbereich bittet um schnelle Freigabe, obwohl Legal noch keine Unterlagen gesehen hat.
- 29.04.2026: externe Partei fragt nach Nachweisen und Fristen.
- 13.05.2026: Geschäftsleitung will eine entscheidungsfähige Vorlage bis Freitagmittag.
- 26.05.2026: mehrere neue Dateien kommen unsortiert per E-Mail und Chat.

Prüffragen

1. Welche Entscheidung soll am Ende unterschrieben werden?
2. Welche Unterlagen fehlen noch wirklich?
3. Welche technische oder wirtschaftliche Tatsache darf nicht einfach unterstellt werden?
4. Wer kann verbindlich Auskunft geben?
5. Welche Rechtsquelle muss live geprüft werden?

Krisenstabs-Runbook — Auszug

Aktivierungstrigger

Der Krisenstab wird aktiviert, sobald **eines** der folgenden Ereignisse eintritt:

- Vermuteter oder bestätigter Einbruch in produktive IT-Systeme (Produktion, Engineering, ERP, M365-Tenant).
- Eingehende Sicherheitswarnung des BSI, eines CERT, eines Versicherers oder eines Geschäftspartners mit konkretem Bezug auf Lahnwerke-Systeme.
- Ungeplanter Ausfall von M365 (Teams/Outlook/SharePoint) länger als 60 Minuten in Verbindung mit ungewöhnlichem Verhalten.
- Verlust eines mit Lahnwerke-Daten konfigurierten Endgeräts (Laptop, Smartphone, AirTag-bewehrte Werkstücke), insbesondere mit Hinweisen auf gezielten Diebstahl.
- Eingehender Hinweis über eine externe Meldestelle (Hinweisgeber, Auditor, Kunde) auf konkrete Datenschutz- oder Cybersicherheitsverletzungen.

Besetzung

Rolle	Hauptperson	Vertretung	Eskalationsbefugnis
Krisenstabsleitung	CEO	COO	volle
Informationssicherheit	CISO	Security-Engineer (Bereitschaft)	technisch
Rechtsabteilung	Justiziarin Dr. Wedekind	Stv. Justitiariat	rechtlich, einschl. Anzeigeerstattung
Datenschutz	DSB Frau Brauer (extern)	DSB-Stellvertretung interne IT	DSGVO-Meldung Art. 33
HR / Personal	Personalleitung	Stv. PL	Beschäftigtenkommunikation
Externe Kommunikation	Kommunikationsleitung	Pressesprecher Stahlring AG (Eigentümer)	Pressemitteilungen
IT-Betrieb	Leitung IT-Operations	Bereitschaftsdienst	technische Sofortmaßnahmen
Externer Forensiker	Firma Bittner+Renz, Düsseldorf	Backup: NorthSec, Hamburg	Forensik-Image-Sicherung

Offene Lücken (Stand vor Vorfall)

- **Notfalltelefonliste:** Aktuell nur in SharePoint hinterlegt. Bei M365-Ausfall NICHT verfügbar. Sofortmaßnahme: Liste in verschlüsselter Offline-Kopie (Datentresor, USB) und Papiausdruck im Tresor der Geschäftsleitung; halbjährlicher Test.
- **Out-of-Band-Kommunikation:** Bisher kein Backup-Messenger. Empfehlung: Signal-Gruppe "Lahnwerke-CIRT" mit allen Krisenstabsmitgliedern, parallel SMS-Verteiler.
- **Krisenstabraum:** Bisher kein dedizierter Raum, der vom Hauptnetz abkoppelbar ist. Vorschlag: Besprechungsraum 4-A mit Stand-alone Internetzugang (LTE-Router) als Fallback-Krisenstabraum.
- **Decision-Log:** Bislang ohne strukturierte Vorgabe. Künftig pro Eskalationsstufe Pflichtprotokoll mit Zeitstempel, Beschluss, Begründung, Verantwortlichem.

0-30-Minuten-Checkliste

1. Alarm via Telefon an Krisenstabsleitung (CEO) und CISO; bei Nicht-Erreichbarkeit über Vertretungsliste durchrufen.
2. Erste Einschätzung CISO: betroffene Systeme, geschätzter Datenumfang, externe Sichtbarkeit.
3. Justiziarin entscheidet über sofortige NIS2-Frühwarnung (innerhalb 24 Stunden an BSI nach § 32 BSIG iVm NIS2-Umsetzung) und DSGVO-Meldung (innerhalb 72 Stunden nach Art. 33 DSGVO).
4. IT-Betrieb beginnt Isolierung betroffener Segmente, sichert Logs, hält forensisches Image vor.
5. Externer Forensiker wird informiert und in Bereitschaft gesetzt.
6. Kommunikationsleitung bereitet **Holding-Statement** vor (keine Veröffentlichung ohne Krisenstabsleitung).

30-Minuten-bis-4-Stunden-Checkliste

1. Krisenstab tagt physisch oder per Signal/Telefon — kein M365.
2. Decision-Log starten, Verantwortlichkeiten dokumentieren.
3. Eingehende Anfragen (Kunden, Presse, Beschäftigte) zentral kanalisieren über Kommunikationsleitung.
4. Konkrete NIS2-Frühwarnung an BSI vorbereiten; bei wesentlicher Beeinträchtigung Meldung über das BSI-Meldeportal absetzen (Konto siehe Justizariat).
5. Bei personenbezogenen Daten: Vorabprüfung Art. 33 DSGVO durch DSB; bei "wahrscheinlich Risiko für Rechte und Freiheiten" → Meldung an Landesdatenschutzaufsicht.

4-bis-24-Stunden-Checkliste

1. Erste forensische Erkenntnisse: Eindringvektor, Persistenzmechanismen, betroffene Datenkategorien.
2. NIS2-**Erstmeldung** an BSI ergänzen (sofern noch nicht abgesetzt).
3. Versicherung (Cyber-Police) informieren — Frist je Police prüfen, oft 48 Stunden.
4. Bei betroffenen Geschäftspartnern: vertragliche Informationspflichten (AVV, B2B-Verträge) auswerten.
5. Beschäftigtenkommunikation: kurze, sachliche Mitteilung; Hinweis auf Mitwirkungspflichten und Pressekontakt-Verbot.

24-bis-72-Stunden-Checkliste

1. NIS2-**Folgenotmeldung** mit konkretem Schadensbild.
2. Art. 33 DSGVO Meldung absetzen, sofern Erkenntnisse die Risikoeinschätzung bestätigen.
3. Bei Betroffenen-Risiko nach Art. 34 DSGVO: Benachrichtigung der Betroffenen vorbereiten.
4. Externer Krisenkommunikator (auf Bereitschaft) erstellt Q&A für Presse und Vertrieb.
5. Aufsichtsrat informieren (gemäß § 90 AktG, soweit konzernrechtlich einschlägig — Stahlring AG als Eigentümerin).

Nach Abschluss

- Vollständige Schlussmeldung an BSI gemäß NIS2-Vorgaben.
- Lessons-Learned-Workshop binnen 4 Wochen.
- Anpassung dieses Runbooks; Versionierung mit Datum und Verantwortlichem im Krisenstabsraum.

Java / PKI — Zertifikatsnotiz und Risikobewertung

Tatsache

Das **Code-Signing-Zertifikat** für die Java-Build-Pipeline der Lahnwerke-Produktfirmware läuft am **09.07.2026** ab. Der Keystore mit dem privaten Schlüssel liegt nach Auskunft des Engineering-Teams aktuell **auf einem CI/CD-Runner-Volume** in einem Azure-DevOps-Pool, eingebunden als Persistent Volume (PV). Der **HSM-Einsatz** (Hardware Security Module) war im IT-Budget 2025 bereits eingeplant, wurde aber nie beauftragt — die Beschaffung scheiterte mehrfach an der Klärung der Verantwortlichkeit zwischen IT und Produktentwicklung. Der **Release 4.8** der Produktfirmware (geplant für 18.06.2026) hängt direkt am Zertifikat: Ohne gültige Signatur akzeptieren weder Engineering-Hosts noch Kundenanlagen die neue Firmware.

Identifizierte Risiken

1. Ablaufrisiko Zertifikat (Compliance / Operations)

- Ohne rechtzeitige Erneuerung **wird Release 4.8 nicht ausgespielt werden können**.
- Bei Lieferverzug an Kunden mit vertraglich vereinbartem Release-Datum: Vertragsstrafenrisiko nach VOB-/Werk-/Liefervertragsklauseln; betroffen sind insbesondere die Kunden "Stahling AG" (interner Konzernkunde) und "MARSEN GmbH" (Verzug-Pönale 5.000 EUR/Werktag).
- Bei nicht-signierten Notfall-Hotfixes: Eskalation in Kundeneinsatz.

2. Keystore-Lokalisierung (IT-Sicherheit)

- Der **Keystore auf einem Runner-Volume** widerspricht den allgemeinen Empfehlungen des BSI (BSI TR-03145) und der NIST SP 800-57. Korrekte Aufbewahrung wäre in einem HSM oder mindestens in einem dedizierten Vault mit Hardware-Bindung.
- Bei Kompromittierung des Runner-Volumes (etwa durch Diebstahl der CI-Pipeline-Credentials, kompromittierte Build-Skripte oder Insider-Zugriffe) wäre der private Schlüssel exfiltrierbar.
- Anschließende Schadenswirkung: Angreifer könnte beliebige Firmware signieren und in die Lahnwerke-Produktbasis einspeisen — **Lieferkettenangriff-Szenario** (z. B. SolarWinds-Typ).
- Diese Risikolage ist im Sinne der NIS2-Richtlinie (Art. 21 NIS2 iVm § 30 BStG) ein "Cybersicherheitsrisiko, das angemessenes Risikomanagement erfordert" und unterliegt der Verantwortung der Geschäftsleitung.

3. Versäumte HSM-Beschaffung (Compliance Governance)

- HSM war 2025 budgetiert (intern Position "IT-Hardware 2025-IT-077"), wurde aber nie beschafft.
- Verantwortlich für die nicht-Beschaffung: ungeklärte Schnittstelle zwischen IT-Operations und Produktentwicklung; faktisch niemand.
- Geschäftsleitung muss **dokumentieren**, warum die Risikoreduzierungsmaßnahme nicht umgesetzt wurde, und welche kompensierenden Maßnahmen ergriffen wurden. Bei späterem Sicherheitsvorfall ist diese Dokumentation für die Frage der Geschäftsleiterhaftung (§ 91 Abs. 2 AktG; § 43 GmbHG) und Compliance-Pflicht entscheidend.

Sofortmaßnahmen (heute)

Operations (24-48 Stunden)

1. **Beschaffung eines Cloud-HSM** (z. B. Azure Key Vault Premium mit FIPS-140-2 Level 2 HSM, oder AWS CloudHSM) — schnellste Option, ohne Wartezeit auf physisches HSM.
2. **Schlüsselrotation**: Neuen Schlüssel im HSM erzeugen, neues Zertifikat bei der CA beantragen, alte Build-Pipeline auf neuen Schlüssel umstellen.
3. **Runner-Volume bereinigen**: privaten Schlüssel löschen, Audit-Log sichern.

Compliance (1 Woche)

1. **Risikoregister-Eintrag**: aktuelles Risiko vollständig dokumentieren mit Schadenshöhe, Eintrittswahrscheinlichkeit, Mitigationsstatus.
2. **Geschäftsleitungs-Information**: Memo mit Risiko, Maßnahme, Restrisiko zur Kenntnisnahme.
3. **NIS2-Pflichtenprüfung**: Klären, ob das vorhandene Risiko ein "wesentlicher Sicherheitsvorfall" iSv § 32 BSIG (Umsetzung NIS2) wäre und ob Meldepflicht besteht. **Vorab**: derzeit kein Sicherheitsvorfall, sondern erkanntes Risiko — keine Meldepflicht; aber Dokumentationspflicht.

Strategie (4 Wochen)

1. **Physisches HSM** beschaffen für langfristigen Einsatz (Nitrokey HSM oder Yubico YubiHSM; alternativ Thales nShield für Enterprise).
2. **Verantwortlichkeits-Matrix** zwischen IT-Ops und Produktentwicklung neu definieren — wer ist für CI/CD-Sicherheit ressortverantwortlich.
3. **Audit der gesamten CI/CD-Pipeline**: weitere Geheimnisse (Secrets, Tokens, Zertifikate) lokalisieren und in den Vault verlagern.

NIS2-Relevanz

- **Art. 21 NIS2** (Maßnahmen für Cybersecurity-Risikomanagement): Kryptografie, Zugangskontrolle, Lieferkettenschutz sind Pflichtmaßnahmen.
- **Geschäftsleitungs-Pflichten** Art. 20 NIS2 (in deutscher Umsetzung § 35 BSIG): Geschäftsleitung muss "die getroffenen Maßnahmen genehmigen, deren Umsetzung beaufsichtigen und kann persönlich haftbar werden, wenn sie ihre Pflichten verletzt".
- Bei einem späteren Vorfall, der auf den hier dokumentierten Mangel zurückgeht, wäre die Frage zu beantworten: warum wurde das Risiko nicht behoben?

Verantwortlichkeiten

- **CISO**: heute Risikoregister aktualisieren, Cloud-HSM-Beschaffung anstoßen.
- **IT-Operations**: Schlüsselrotation operationell vorbereiten.
- **Geschäftsleitung**: Memo bis 06.06.2026 zur Kenntnisnahme; Freigabe Beschaffung.
- **Externe Beratung**: Spezialfrage Schlüsselverwaltung in CI/CD-Pipelines an Beratung Klein+Steinberg (vorgesehen).

Datei: 21-offene-punkte-und-lueckenliste.md

Offene Punkte und Lückenliste — NIS2-Cybersicherheit Lahnwerke

Status

Stand: 02.06.2026. Mandant: Lahnwerke GmbH (Industrieprodukte, Konzerntochter Stahlring AG).
Beratung: Dr. Henning Brettschneider (IT-/Cybersecurityrecht), Senior Associate L. Wenstedt.

Offene Punkte

1. Rechtsquellen-Live-Check

- **BSIG** in der Fassung des NIS2-Umsetzungsgesetzes 2024/2025; insbesondere die §§ 28-37 BSIG (Risikomanagement, Meldepflicht, Geschäftsleitungspflichten). Live gegen ``gesetze-im-internet.de`` verifizieren.
- **NIS2-Richtlinie 2022/2555**: aktueller Stand der nationalen Umsetzung in den Mitgliedstaaten relevant, weil Lahnwerke auch in Österreich, Polen, Tschechien aktiv ist.
- **DSGVO Art. 32-34**: technische und organisatorische Maßnahmen, Meldepflichten, Benachrichtigung Betroffener.
- **Cyber Resilience Act (EU 2024/2847)**: relevant für die Frage, ob Lahnwerke-Produkte unter die Vorgaben fallen — Übergangsfrist beachten.
- **DigitalEU-VO 2018/1807**: freier Datenverkehr nicht-personenbezogener Daten — relevant für Cloud-Setup-Frage.

2. Fehlende technische und kaufmännische Nachweise

- **Vollständiges Asset-Inventar**: Aktuelles Asset-Inventar liegt mit Stand 03/2025 vor. Müsste auf den Stand 06/2026 aktualisiert werden — insbesondere zu OT-Komponenten (Sensorik, Steuerungen).
- **Lieferketten-Inventar**: Welche Drittanbieter haben Zugriff auf Lahnwerke-Systeme? Vollständige Liste der SaaS-Anbieter (Slack, M365, Teams-Telefonie, Salesforce, AzureDevOps), Cloud-Provider, externe Wartungsfirmen.
- **Patch-Management-Berichte** der letzten 12 Monate.
- **Notfallübungs-Protokolle** der letzten 24 Monate (existieren in welchem Umfang?).
- **Schulungsnachweise** für Beschäftigte zu Phishing und Cybersecurity.
- **AVV-Verträge mit Drittanbietern**: vollständig? Aktualität?
- **Verträge mit dem externen Forensiker** (Bittner+Renz, NorthSec): SLA, Bereitschaftsstufen, Tagessätze.

3. Widersprüche und Inkonsistenzen

- **Slack-Nutzung vs. interne Richtlinie**: Lahnwerke-IT-Richtlinie 2024 verbietet die Nutzung externer Messenger für vertrauliche Kommunikation. Tatsächlich nutzen Engineering und Vertrieb Slack intensiv. Diskrepanz zwischen Richtlinie und Praxis dokumentieren.
- **AirTag-Verwendung an Werkstücken**: Aktenstück 14 dokumentiert, dass Lahnwerke AirTags zur Verfolgung von Werkstücken (Lieferung an Kunden) verwendet. Datenschutzrechtliche Bewertung (Datenfluss an Apple, personenbeziehbarer Standort) ist nicht dokumentiert.
- **MFA-Coverage**: Behauptung im internen Report 04/2026: "MFA bei 95 % aller Accounts aktiv". Tatsächlich: nur 70 %, weil mehrere Service-Accounts und Wartungs-Accounts ausgenommen. Lücke

schließen.

4. Beweisfundstellen für harte Aussagen

- Behauptung "Lahnwerke ist NIS2-pflichtig": derzeit nur Vermutung über Größenklassifizierung. Bessere Belege: Jahresabschluss Beschäftigtenzahl, Konzernzuordnung, Sektorzuordnung nach Anhang I/II der Richtlinie.
- Behauptung "kein wesentlicher Vorfall seit 2023": derzeit auf interne Vorfalls-Logs gestützt; vollständige Aufstellung mit Klassifikation nach NIS2-Wesentlichkeitskriterien anfertigen.
- Behauptung "Geschäftsleitung ist über Cybersecurity-Lage informiert": derzeit nur indirekt aus Aufsichtsratsprotokollen. Bessere Belege: konkrete Sitzungsprotokolle Geschäftsleitung mit ausdrücklicher Cybersecurity-Berichterstattung.

Lückenliste (Dokumente)

Lücke	Beweisthema	Beschaffungsweg	Frist	Verantwortlich	Status
Aktualisiertes Asset-Inventar	NIS2 § 30 BSIG	intern IT	4 Wochen	CISO	offen
Lieferketten-Inventar	NIS2 § 30 BSIG	intern Einkauf + IT	3 Wochen	Einkauf	offen
Patch-Management-Berichte 06/2025-06/2026	Sorgfalt	intern IT	1 Woche	IT-Operations	beauftragt
Notfallübungs-Protokolle	NIS2 Risikomanagement	intern CISO	2 Wochen	CISO	offen
Schulungsnachweise Cybersecurity	NIS2 Schulungspflicht	HR	1 Woche	HR	beauftragt
AVV-Verträge alle SaaS-Anbieter	DSGVO Art. 28	Justizariat	2 Wochen	Justizariat	initialisiert
Forensiker-SLA	Bereitschaft Vorfall	Justizariat	1 Woche	Justizariat	gemacht
Cloud-HSM-Beschaffung Code-Signing	siehe Aktenstück 18	IT-Operations	5 Werktage	CISO	beauftragt
Datenschutzbewertung AirTag-Nutzung	DSGVO + § 4f BDSG	DSB	2 Wochen	DSB	initialisiert
Slack-Nutzungsbewertung	Geschäftsgeheimnisse + DSGVO	DSB + Justizariat	2 Wochen	DSB	initialisiert
Notfalltelefonliste offline	siehe Aktenstück 16	Sekretariat	5 Werktage	Sekretariat	beauftragt
MFA-Coverage 100 %	Sorgfalt § 30 BSIG	IT-Operations	3 Wochen	IT-Operations	offen

Grundregeln für die Aktenbearbeitung

- Originalquellen und aktuelle Gesetzesfassungen live prüfen — nicht aus älteren Schriftsätzen übernehmen.
- Fehlende technische oder kaufmännische Nachweise nicht durch Vermutungen ersetzen — als Lücke führen, gezielt schließen.
- Widersprüche zwischen Richtlinie, Tatsache und Vertrag explizit benennen — Risiko der unredlichen Compliance-Behauptung.
- Für jede harte Aussage Aktenfundstelle nennen — andernfalls "noch zu belegen" markieren.
- Geschäftsleitungs-Information dokumentieren, damit § 30 BSIG / Art. 20 NIS2-Pflichten nachweisbar sind.

Nächste Aktualisierung

Donnerstag, 04.06.2026, 14:00 Uhr — vor der Geschäftsleitungssitzung.

Datei: 09-email-ciso-an-legal.eml

Von	ciso@lahnwerke.example
An	legal@lahnwerke.example
Datum	Tue, 26 May 2026 07:42:00 +0000
Betreff	Freigabe Slack / NIS2 / AirTags - brauche belastbare Linie

Guten Morgen,

der Vorstand will am Freitag entscheiden. Ich möchte nicht nur die üblichen Zertifikate zeigen, sondern eine echte Linie: NIS-2/BSIG, BSI-Grundschutz, Slack, AirTags, MDM, Java-Zertifikate und Incident-Meldeweg. Bitte auch aufnehmen, wo wir noch keine Nachweise haben.

Viele Grüße

Marlene

Datei: 10-email-einkauf-supplier-remote.eml

Von	service@frankenturm-automation.example
An	einkauf@lahnwerke.example
Datum	Sat, 23 May 2026 14:06:00 +0000
Betreff	Dauerhafter VPN-Tunnel für Pressenwartung

Hallo,

für die neue Pressenlinie benötigen wir dauerhaft offenen VPN-Zugang aus unserem Servicecenter. Unser Standardvertrag sieht keine Session-Aufzeichnung vor. Ohne Zugriff verlieren Sie die Reaktionszeit im SLA.

Gruß

K. Rehbaum

Datei: 15-betriebsrat-mdm-airtags.eml

Von	br@lahnwerke.example
An	vorstand@lahnwerke.example
Datum	Sun, 24 May 2026 16:22:00 +0000
Betreff	MDM, AirTags und neue Logging-Regeln

Sehr geehrte Damen und Herren,

wir verlangen Beteiligung vor Einführung weiterer MDM-, Tracking- und Loggingmaßnahmen. Uns liegt eine Liste von acht Fahrzeugen mit AirTags vor. Bitte stoppen Sie den Rollout bis zur Klärung der Zwecke, Zugriffsrechte und Löschrufen.

Betriebsrat

Datei: 08-asset-inventar-auszug.csv

Asset	Typ	Owner	Kritikalität	Nachweis
SAP S4	ERP	IT Betrieb	hoch	CMDB
LKW AirTags	Tracker	Logistik	mittel	nur Excel
Code Signing CA	PKI	Engineering	hoch	unvollständig
Slack	SaaS	IT Collaboration	hoch	Security Memo

Datei: 19-lieferanten-questionnaire.csv

Frage	Antwort Lieferant	Nachweis	Bewertung
MFA Fernwartung	ja	Screenshot Admin Portal	gelb
Session Recording	nein	Standardvertrag	rot
Incidentmeldung 24h	unklar	SLA	rot
Subunternehmer	Polen/Indien	Liste	gelb

Datei: 22-anlagenindex.csv

Datei	Dokumenttyp	Wichtigkeit	Bemerkung
01-mandatsnotiz-und-arbeitsauftrag.md	MD	mittel	Erste Lage, Personen, Ziel und offene Fragen
02-zeitstrahl-und-fristen.md	MD	mittel	Chronologie mit Entscheidungs- und Eskalationspunkten
03-prueffragen-fuer-erstgesprach.md	MD	mittel	Katalog für das erste strukturierte Gespräch
04-vorstandsvorlage-cyber-roadmap.docx	DOCX	hoch	Entwurf Vorstandsvorlage zur Cyber-Roadmap
05-cyber-risk-register.xlsx	XLSX	hoch	Risikoregister mit Maßnahmen, Ownern und Fristen
06-nis2-betroffenheitsvermerk.pdf	PDF	hoch	Vermerk zur vorläufigen NIS-2-/BSIG-Betroffenheit
07-slack-cloud-security-memo.pdf	PDF	hoch	Cloud-/SaaS-Prüfung Slack-Rollout
08-asset-inventar-auszug.csv	CSV	mittel	Asset-Inventar mit Lücken
09-email-ciso-an-legal.eml	EML	hoch	CISO fragt Legal nach Leitungsvorlage
10-email-einkauf-supplier-remote.eml	EML	mittel	Lieferant bittet um dauerhafte Fernwartung
11-backup-restore-protokoll.pdf	PDF	mittel	Restore-Test mit erkennbaren Lücken
12-whatsapp-it-legal.jpg	JPG	mittel	Chat-Screenshot IT/Legal mit operativer Dringlichkeit
13-screenshot-siem-alerts.jpg	JPG	mittel	SIEM-/SOC-Screenshot als Bilddatei
14-policy-entwurf-screenshots-und-chat.docx	DOCX	mittel	Policy-Entwurf Screenshots und Chat

Datei	Dokumenttyp	Wichtigkeit	Bemerkung
15-betriebsrat-mdm-airtags.eml	EML	mittel	Betriebsrat verlangt Beteiligung
16-krisenstabs-runbook-auszug.md	MD	mittel	Runbook-Auszug Krisenstab
17-cloud-provider-c5-luecken.pdf	PDF	mittel	Cloud-Provider-Prüfung C5/Region/Exit
18-java-pki-zertifikatsnotiz.md	MD	mittel	Notiz zu Java-Code-Signing und PKI
19-lieferanten-questionnaire.csv	CSV	mittel	Supplier-Security-Fragebogen
20-board-briefing-draft.pdf	PDF	mittel	Board-Briefing als Arbeitsstand
21-offene-punkte-und-lueckenliste.md	MD	mittel	Offene Punkte und Lückenliste
22-anlagenindex.csv	CSV	mittel	Anlagenindex

Tabellenblatt: Risiken

ID	Risiko	Asset	Impact	Kontrolle	Owner	Frist	Status
R-01	Ransomware verschlüsselt ERP und Produktionsplanung	SAP + Fileserver	sehr hoch	Immutable Backup + Restore-Test	CISO	2026-06-21	gelb
R-02	Slack-Screenshots enthalten Kundendaten und VPN-Token	Slack Enterprise Grid	hoch	DLP + Screenshot Policy	Legal/IT	2026-06-12	rot
R-03	AirTags an LKW erzeugen Beschäftigten Daten ohne BV	Fuhrpark	mittel	Betriebsvereinbarung + Zweckbindung	HR	2026-06-30	gelb
R-04	Java-Code-Signing-Zertifikat läuft im Juli ab	Build Pipeline	hoch	PKI-Inventar + HSM-Prüfung	Engineering	2026-06-10	rot

Tabellenblatt: Nachweise

Nachweis	Akte	Fehlt
Restore-Test	11-backup-restore-protokoll.pdf	vollständiger AD-Recovery-Test
Betriebsrat	15-betriebsrat-mdm-airtags.eml	Beschlussfassung
Cloud C5	07-slack-cloud-security-memo.pdf	Subprozessorenliste

Vorstandsvorlage Cyber-Roadmap

Die Lahnwerke Maschinenbau AG betreibt Produktions-IT, ein europaweites Ersatzteillager, Telematik in 88 LKW und mehrere Cloud-SaaS-Dienste. Die Vorstandsvorlage soll keine bloße Zertifikatsliste werden, sondern die Entscheidung über Budget, Verantwortlichkeit und Nachweise ermöglichen.

Der CISO hält eine NIS-2-Betroffenheit für wahrscheinlich, aber die Sektorzuordnung ist nicht sauber dokumentiert. Einkauf und Logistik möchten Slack und AirTags sofort freigeben; HR verlangt Betriebsratsbeteiligung.

Die kritischsten offenen Punkte sind Lieferanten-Fernwartung, fehlende Restore-Tests, Zertifikatsabläufe in Java-Signierprozessen und unklare Screenshot-Regeln in Supportkanälen.

BSIG 2025 und NIS-2 live prüfen

BSI-Grundschutz-Schutzbedarf sauber dokumentieren

Slack/MDM/AirTags nicht getrennt, sondern als Daten- und Securityverbund betrachten

Policy-Entwurf: Screenshots und Chatkanäle

Screenshots aus Logs, Tickets und Kundenumgebungen dürfen nicht ungeprüft in offene Chatkanäle gestellt werden. Tokens, personenbezogene Daten, Gesundheitsdaten, Kundengeheimnisse und Quellcode werden vor Weitergabe geschwärzt oder in freigegebene Systeme verschoben.

Externe Channels benötigen einen verantwortlichen Owner, Ablaufdatum und Datenklasse.

Keine privaten Messenger für Kundenstörungen

Sicherheitsvorfälle nur im Krisenkanal

Legal Hold wird gesondert angeordnet

Kurzfassung Entscheidungsvorlage

Lahnwerke Maschinenbau AG rollt Slack aus, verfolgt LKW-Werkzeugcontainer mit AirTags, betreibt MDM auf Firmenhandys und hat nach einem Lieferanten-VPN-Vorfall Zweifel an NIS-2-/BSI-Reife.

Die Entscheidung sollte nicht auf Grundlage einzelner Schlagworte getroffen werden. Maßgeblich sind Nachweisbarkeit, Zuständigkeit, Frist und ein realistischer nächster Schritt.

Rote Punkte zuerst behandeln

Quellen live prüfen

Offene Tatsachen ausdrücklich offen lassen

IT / Legal 26.05.

IT

Wenn wir Slack morgen nicht freigeben, ziehen Vertrieb und Service weiter über private WhatsApp-Gruppen.

Legal

Dann lieber sauber schnell: Datenklassen, externe Gäste, Screenshot-Regel, Betriebsrat, Adminrechte.

IT

AirTags an LKWs hängen schon an acht Fahrzeugen. Logistik sagt Diebstahlschutz.

Legal

Dann muss das in dieselbe Vorlage. Zweckbindung, Beschäftigtendaten, Zugriff, Löschung.

SOC Alerts

SOC

High: impossible travel admin@lahnwerke

SOC

Medium: expired certificate build-signing-02 in 32
Tagen

SOC

Low: external Slack guest invited to channel
#customer-vpn-log

Bilddatei: 13-screenshot-siem-alerts.jpg

Datei

PDF-Anhang: 06-nis2-betroffenheitsvermerk.pdf

Vorläufiger Betroffenheitsvermerk

Die Gesellschaft liefert Ersatzteile an Energie- und Verkehrskunden, betreibt aber zugleich eigene digitale Dienste für Fernwartung. Die Einordnung hängt davon ab, welche Dienste tatsächlich am Markt erbracht werden und welche Konzernschwellen erreicht sind.

Nicht ausreichend ist die Aussage, man sei ISO-zertifiziert. Entscheidend ist, welche Pflichten nach NIS-2/BSIG ausgelöst werden, wer registriert, wer meldet und welche technischen Maßnahmen tatsächlich getestet sind.

Punkt	Sachstand	Risiko
Sektor	Produktion plus digitale Fernwartung	Einordnung offen
Größe	ca. 780 MA Konzernverbund	Schwelle wahrscheinlich
Meldung	Incidentprozess nicht getestet	rot

Datei

PDF-Anhang: 07-slack-cloud-security-memo.pdf

Slack-Rollout: Security- und Legal-Prüfung

Fachbereiche möchten Slack mit externen Channels für Großkunden nutzen. Die Richtlinie muss regeln, welche Datenklassen dort erscheinen dürfen, wie Screenshots behandelt werden und wer externe Gäste freigibt.

Technisch fehlen noch DLP-Regeln, Aufbewahrungskonzept, Admin-Rollen, Exportprozess und Abgleich mit Betriebsrat und Datenschutz.

Thema	Entscheidung
Externe Gäste	nur mit Owner und Ablaufdatum
Screenshots	keine Tokens, keine Personaldaten, keine ungeprüften Logs
Retention	Legal Hold mit DSGVO-Abwägung

Datei

PDF-Anhang: 11-backup-restore-protokoll.pdf

Restore-Test 14.05.2026

Der Restore des Fileservers gelang nach 6 Stunden. Der ERP-Test wurde abgebrochen, weil die AD-Recovery-Dokumentation nicht auffindbar war. Der Dienstleister hat zugesagt, eine zweite Übung vorzuschlagen.

Die Geschäftsleitung soll nicht nur Backup-Erfolg melden, sondern offen dokumentieren, dass ein vollständiger Wiederanlauf noch nicht bewiesen ist.

System	Ergebnis	Lücke
Fileserver	OK	RPO 12h
ERP	abgebrochen	AD-Recovery fehlt
Telefonie	nicht getestet	Fallback unklar

Datei

PDF-Anhang: 17-cloud-provider-c5-luecken.pdf

Cloud-Provider-Prüfung

Der Provider verweist auf ein C5-Testat, liefert aber nur eine Zusammenfassung. Die Subdienstleisterliste enthält Supportzugriffe aus mehreren Regionen. Der Exit-Test wurde noch nie durchgeführt.

Für die Vorstandsvorlage ist zu trennen: Vertraglich zugesagt, technisch implementiert, auditiert, ungeprüft.

Kontrolle	Nachweis	Bewertung
C5	Executive Summary	gelb
Subprozessoren	Liste 2025	gelb
Exit	kein Test	rot

Datei

PDF-Anhang: 20-board-briefing-draft.pdf

Board-Briefing Arbeitsstand

Die Gesellschaft sollte den Rollout nicht stoppen, aber an rote Mindestbedingungen knüpfen: externe Slack-Channels nur mit Owner, AirTag-Zugriff nur für Logistik-Leitung und Betriebsvereinbarung, Fernwartung nur mit MFA und Session Recording, Restore-Test binnen vier Wochen.

Nächster Beschluss: Budget für PKI/HSM, SOC Use Cases und Lieferantenkontrolle freigeben.

Beschluss	Frist	Owner
Slack Controlled Rollout	14 Tage	CISO
AirTag BV	30 Tage	HR
Restore-Test	4 Wochen	IT Betrieb

Datei

PDF-Anhang: 24-arbeitsstand-fuer-besprechung.pdf

Besprechungsunterlage

Diese Unterlage bündelt den Arbeitsstand für die nächste Besprechung. Sie ersetzt keine abschließende Prüfung, sondern sortiert Unterlagen, Entscheidungen und Lücken.

Bitte in der Besprechung zuerst klären, welche Entscheidung wirklich heute gebraucht wird.

TOP	Frage
1	Was muss entschieden werden?
2	Welche Quelle fehlt?
3	Wer liefert Nachweise?
4	Welcher Text wird benötigt?